

SOCIAL ENGINEERING AWARENESS

1. INTRODUCTION

Social engineering is a cybersecurity attack technique in which attackers manipulate people into revealing confidential information, providing unauthorized access, transferring money, or performing actions that compromise security.

Unlike attacks that directly target technical vulnerabilities, social engineering primarily targets **human behavior, trust, emotions, and decision-making**.

Attackers may pretend to be employees, managers, IT support staff, banks, government officials, delivery personnel, or other trusted individuals. They often create a sense of **urgency, fear, curiosity, or authority** to pressure victims into acting without verifying the request.

Social engineering is a major cybersecurity concern because even strong technical security controls can be weakened if a user is successfully manipulated.

2. OBJECTIVE

The main objective of this task is to understand how human behavior can be targeted by attackers and to identify common social engineering techniques and warning signs.

Specific Objectives

1. Understand the concept of social engineering.
 2. Identify common social engineering attacks.
 3. Understand how attackers manipulate human behavior.
 4. Recognize warning signs of social engineering attempts.
 5. Understand the concept of pretexting.
 6. Learn how employees can prevent social engineering attacks.
 7. Develop awareness about suspicious requests, impersonation, and urgency.
-

3. WHAT IS SOCIAL ENGINEERING?

Social engineering is the use of **psychological manipulation and deception** to influence a person into taking an action that may compromise security.

The attacker may attempt to make the victim:

- Reveal a password

- Share an OTP
- Click a malicious link
- Open a harmful attachment
- Transfer money
- Provide confidential information
- Allow unauthorized access
- Install malicious software

Example

An attacker calls an employee and says:

"I am from the IT department. Your account has a security issue. Please provide your OTP so I can verify your identity."

The attacker is using **impersonation and urgency** to manipulate the employee.

The employee should not provide the OTP and should independently verify the request.

4. WHY SOCIAL ENGINEERING WORKS

Social engineering attacks work because attackers exploit normal human characteristics and emotions.

Common psychological factors exploited by attackers include:

1. Trust

People tend to trust individuals who appear to be legitimate.

2. Fear

Attackers may threaten account suspension, legal action, or financial loss.

3. Urgency

Attackers may create pressure by saying that immediate action is required.

4. Authority

Attackers may pretend to be managers, executives, police officers, bank employees, or IT staff.

5. Curiosity

Attackers may use interesting or shocking messages to encourage users to click links.

6. Helpfulness

Attackers may take advantage of employees who want to help colleagues or customers.

5. COMMON SOCIAL ENGINEERING TECHNIQUES

5.1 Phishing

Phishing is a social engineering technique in which attackers send fraudulent emails or messages designed to trick users into revealing information or clicking malicious links.

Example

An employee receives an email appearing to come from the organization's HR department asking them to log in through a provided link.

The link leads to a fake login page designed to steal credentials.

Warning Signs

- Suspicious sender address
- Unexpected request
- Urgent language
- Suspicious links
- Spelling or grammatical errors
- Request for confidential information

Prevention

- Verify the sender.
 - Avoid suspicious links.
 - Check the actual website address.
 - Do not provide passwords or OTPs.
 - Report suspicious messages.
-

6. SPEAR PHISHING

Spear phishing is a targeted form of phishing directed at a specific individual or organization.

Attackers may research the victim before sending the message to make it appear more convincing.

Example

An attacker researches a company's employees and sends a personalized email pretending to be the employee's manager.

The email asks the employee to send confidential company information.

Warning Signs

- Unexpected personalized requests
- Unusual communication from a known person
- Request for confidential information
- Urgent instructions

Prevention

- Verify unusual requests through another communication channel.
 - Avoid sharing confidential information through unexpected messages.
 - Follow organizational procedures.
-

7. VISHING

Vishing stands for **Voice Phishing**.

It involves using phone calls or voice communication to deceive victims.

Example

An attacker calls an employee pretending to be a bank representative and asks for an OTP to "verify the account."

Warning Signs

- Unexpected phone call
- Request for OTP or password
- Pressure to act immediately
- Threats of account suspension
- Caller refuses to provide verifiable information

Prevention

- Never share passwords or OTPs over phone calls.
- End suspicious calls.
- Contact the organization using an official phone number.
- Report suspicious calls.

8. SMISHING

Smishing is phishing performed through **SMS or messaging applications**.

Example

A user receives a message saying:

"Your bank account will be blocked today. Click this link to verify your account."

The link may lead to a fake website.

Warning Signs

- Unknown sender
- Shortened or suspicious links
- Urgent messages
- Requests for personal information
- Unexpected payment requests

Prevention

- Do not click suspicious links.
 - Verify the message through official channels.
 - Never provide passwords or OTPs through messages.
-

9. PRETEXTING

Pretexting is a social engineering technique in which an attacker creates a **false story or scenario**, known as a pretext, to obtain information or persuade a victim to perform an action.

Example

An attacker pretends to be an IT support employee and tells a staff member:

"We are performing a security check on your account. Please provide your employee ID and login information."

The attacker has created a false situation to obtain sensitive information.

Warning Signs

- Unusual requests
- Request for confidential information
- Unknown individual claiming to be an employee

- Pressure to bypass normal procedures

Prevention

- Verify the person's identity.
 - Follow organizational procedures.
 - Never share passwords.
 - Contact the department through an official channel.
-

10. BAITING

Baiting involves offering something attractive to the victim in order to trick them into performing an unsafe action.

Example

An attacker leaves a USB drive labelled "Employee Salary Information" in a company parking area.

A curious employee inserts it into their computer, potentially allowing malware to execute.

Warning Signs

- Unknown USB drives
- Unexpected gifts or files
- Free software from untrusted sources
- Attractive offers that seem suspicious

Prevention

- Never use unknown USB devices.
 - Do not download suspicious software.
 - Report unknown devices to IT/security personnel.
-

11. QUID PRO QUO

Quid pro quo attacks involve offering a benefit or service in exchange for information or access.

Example

An attacker pretends to be technical support and offers to fix an employee's computer in exchange for login credentials.

Prevention

- Verify support personnel.
 - Use official IT support channels.
 - Never provide passwords to support staff.
 - Do not allow unauthorized individuals to access systems.
-

12. TAILGATING

Tailgating occurs when an unauthorized person physically follows an authorized person into a restricted area.

Example

An attacker approaches an employee at a secure office entrance and says:

"Could you hold the door for me? I forgot my access card."

The employee allows the person to enter without verifying their authorization.

Prevention

- Do not allow unknown individuals to enter restricted areas.
 - Use access cards properly.
 - Ask visitors to follow the organization's visitor procedures.
 - Report suspicious behavior.
-

13. IMPERSONATION

Impersonation occurs when an attacker pretends to be another person or trusted authority.

The attacker may pretend to be:

- Manager
- CEO
- IT employee
- Bank employee
- Government official
- Customer
- Delivery employee

Example

An attacker sends a message pretending to be the CEO and asks an employee to urgently transfer money to a specified account.

Prevention

- Verify unusual requests.
 - Use known contact information.
 - Follow approval procedures.
 - Do not rely only on email identity.
-

14. COMMON WARNING SIGNS OF SOCIAL ENGINEERING

Employees should be cautious when they notice the following signs:

1. Urgency

The attacker says the action must be completed immediately.

Example:

"Your account will be deleted in 10 minutes."

2. Impersonation

The attacker pretends to be someone trusted.

Example:

"I am from the IT department."

3. Suspicious Requests

The person asks for passwords, OTPs, confidential files, or financial information.

4. Unusual Payment Requests

An employee is asked to transfer money or purchase gift cards unexpectedly.

5. Suspicious Links

The message contains a link that does not appear to belong to the legitimate organization.

6. Threats

The attacker threatens the victim with account closure, legal action, or financial consequences.

7. Secrecy

The attacker tells the victim not to inform anyone else.

8. Unexpected Attachments

An unknown or unexpected file is attached to an email or message.

9. Bypassing Procedures

The attacker asks the employee to ignore normal organizational processes.

10. Emotional Manipulation

The attacker attempts to create fear, excitement, sympathy, or curiosity.

15. SOCIAL ENGINEERING ATTACK SCENARIO

Scenario

An employee receives a phone call from someone claiming to be from the company's IT department.

The caller says:

"There has been suspicious activity on your account. I need your password and OTP immediately to secure it."

Analysis

Threat: Social Engineering

Technique: Impersonation + Urgency

Target: Employee

Information Requested: Password and OTP

Warning Signs:

- Unexpected call
- Impersonation of IT staff
- Urgent request
- Request for sensitive authentication information

Correct Response

The employee should:

1. Refuse to provide the password or OTP.
2. End the call if necessary.
3. Contact the IT department through an official channel.
4. Report the suspicious incident.

5. Monitor the account for unusual activity.

16. HOW EMPLOYEES CAN PREVENT SOCIAL ENGINEERING

1. Verify the Identity

Always verify the identity of a person requesting sensitive information.

2. Do Not Share Passwords

Passwords should never be shared with anyone.

3. Never Share OTPs

Authentication codes should not be disclosed to callers, email senders, or messages.

4. Do Not Trust Urgency

Attackers often create urgency to prevent victims from thinking carefully.

Take time to verify the request.

5. Check Email Addresses

Do not rely only on the displayed sender name. Check the actual email address.

6. Verify Payment Requests

Financial requests should be verified through an independent communication channel.

7. Avoid Suspicious Links

Hover over links where appropriate and verify the destination before opening them.

8. Follow Organizational Procedures

Employees should follow established security and approval procedures even when someone claims to be a manager or executive.

9. Report Suspicious Activity

Suspicious emails, calls, messages, or physical security incidents should be reported to the appropriate security or IT team.

10. Participate in Security Awareness Training

Regular training helps employees recognize new and evolving social engineering techniques.

17. SOCIAL ENGINEERING AWARENESS CHECKLIST

Before responding to a suspicious request, ask:

- Do I know the person making the request?

- Was I expecting this message or call?
- Is the request urgent?
- Is sensitive information being requested?
- Is the sender's identity verified?
- Does the link lead to a legitimate website?
- Is the request different from normal procedures?
- Is someone asking me to bypass security controls?
- Can I independently verify the request?
- Should I report this to the security team?

If something seems suspicious, **stop and verify before taking action.**

18. SOCIAL ENGINEERING PREVENTION POLICY FOR ORGANIZATIONS

Organizations should establish clear security policies to reduce social engineering risks.

Policy Guidelines

1. Employees must never share passwords or authentication codes.
 2. Employees must verify unusual requests for sensitive information.
 3. Financial requests should require appropriate authorization.
 4. Employees should not bypass established security procedures.
 5. Unknown visitors should not be allowed into restricted areas.
 6. Suspicious emails and messages should be reported.
 7. Employees should receive regular cybersecurity awareness training.
 8. Organizations should conduct simulated phishing exercises where appropriate.
 9. Sensitive information should only be shared through approved channels.
 10. Security incidents should be reported immediately.
-

19. SOCIAL ENGINEERING ATTACK COMPARISON

Attack	Method	Target	Example
Phishing	Fake emails/messages	Users	Fake login email
Spear Phishing	Targeted phishing	Specific person	Fake manager email
Vishing	Phone calls	Users	Fake bank/IT call
Smishing	SMS/messages	Mobile users	Fake delivery/bank SMS
Pretexting	False scenario	Employees	Fake IT support
Baiting	Attractive bait	Users	Infected USB drive
Quid Pro Quo	Fake benefit/service	Employees	Fake technical support
Tailgating	Physical access	Employees/facilities	Following employee through secure door
Impersonation	Pretending to be trusted person	Employees	Fake CEO request